

1. Tổng quan về JWT

- **JSON Web Tokens**, thường được gọi là JWT, là một phương pháp phổ biến để truyền thông tin giữa các bên một cách toàn diện. JWT bao gồm ba phần: **header**, **payload**, và **signature**.
 - **Header** : chứa thông tin về loại JWT và thuật toán được sử dụng để ký hiệu trong JWT
 - **Payload** : chứa dữ liệu được truyền đi, có giới hạn như người dùng thông tin, bên trong JWT hành động .v..v
 - **Chữ ký** : được sử dụng để xác định rằng JWT không bị lừa dối.



Header

Payload

Signature

```
base64enc({  
  "alg": "HS256",  
  "typ": "JWT"  
})
```

```
base64enc({  
  "iss": "toptal.com",  
  "exp": 1426420800,  
  "company": "Toptal",  
  "awesome": true  
})
```

```
HMACSHA256(  
  base64enc(header)  
  + '.', +  
  base64enc(payload)  
  , secretKey)
```



- **Lợi ích của JWT**: JWT đã trở thành một phần quan trọng của bảo mật web hiện đại vì nó cung cấp cách truyền thông tin **an toàn hơn cho các phương pháp truyền thông như cookie**. Với cookie, thông tin nhạy cảm như thông tin đăng nhập của người dùng được lưu trữ ở phía máy

khách, khiến nó dễ bị tấn công như tạo kịch bản chéo trang (XSS) và giả mạo yêu cầu giữa các trang (CSRF).

2. Cấu trúc của JWT

- **Tiêu đề (Header):**

Header **chứa thông tin về JWT**, ví dụ như thuật toán (algorithm) được sử dụng để ký hiệu JWT, đồng thời cũng là một JSON đối tượng được mã hóa base64Url. Xem ví dụ sau đây:

```
{
  "alg": "HS256",
  "typ": "JWT"
}
```

Trong ví dụ này, thuộc tính alg thuật toán chỉ định được sử dụng cho ký hiệu JWT (trong trường hợp này là HMAC với **SHA-256**) và thuộc tính "typ" chỉ định rằng mã thông báo này là JWT.

- **Tải trọng (Payload):**

Payload của JWT **chứa thông tin được truyền đi**, được coi là hạn chế như thông tin người dùng hoặc quyền ủy quyền, nó cũng là một JSON đối tượng được mã hóa base64Url. Xem ví dụ sau đây:

```
{
  "sub": "1234567890",
  "name": "John Doe",
  "iat": 1516239022
}
```

Trong ví dụ này, thuộc tính sub chứa ID của người dùng, thuộc tính name chứa tên của người dùng và thuộc tính iat là thời gian mà JWT được phát hiện.

- **Chữ ký (Signature):**

Ký hiệu của JWT được sử dụng để **xác định rằng mã thông báo không bị giả mạo**. Chữ ký được tạo bằng cách lấy header và payload được mã hóa, kết hợp chúng với **khóa bí mật (secret key)** và áp dụng thuật toán được xác định chỉ. Xem ví dụ sau đây:

```
HMACSHA256(
  base64UrlEncode(header) + "." +
  base64UrlEncode(payload),
  secret)
```

Trong ví dụ này, thuật toán HMAC-SHA256 được sử dụng để tạo chữ ký và khóa bí mật được sử dụng để ký vào mã thông báo (JWT).

3. Ưu, nhược điểm của JWT

- **Ưu điểm của JWT:**

- **Không cần lưu trữ session trên server:**
JWT được lưu trữ trên client, giúp giảm tải cho server.
- **Tính stateless:**
Server không cần phải nhớ trạng thái của client, giúp dễ dàng mở rộng hệ thống.
- **Khả năng tương thích cao:**
JWT có thể được sử dụng trong nhiều loại ứng dụng và nền tảng khác nhau.
- **An toàn:**
JWT được ký bằng private key, đảm bảo tính toàn vẹn của thông tin.
- **Nhược điểm của JWT:**
 - **Kích thước lớn:**
JWT có thể lớn hơn so với cookie, đặc biệt khi chứa nhiều thông tin trong payload.
 - **Không thể thu hồi token:**
Một khi JWT đã được tạo, nó có hiệu lực cho đến khi hết hạn, trừ khi có cơ chế revoke token.
 - **Rủi ro nếu token bị đánh cắp:**
Nếu JWT bị đánh cắp, kẻ xấu có thể giả mạo người dùng.